

User, Group, Authentication Hardening Report

Name: Solomon Mwaura

Date: Jan 25th 2026

Role: Junior DevOps Engineer

1. Preparation

Initial Setup and Baseline Audit

1. Pulling the Docker image and entering the container:

```
docker pull nwendlo1/c1w2m6
```

```
docker run -it nwendlo1/c1w2m6 /bin/bash
```

```
cd /usr/bin
```

- `docker pull` downloads the lab image.
- `docker run -it` opens an interactive terminal in the container.
- `cd /usr/bin` navigates to a location where tools like Lynis can be installed.

2. Updating packages and installing Lynis:

```
sudo apt update
```

```
sudo apt upgrade
```

```
sudo apt install lynis
```

- Ensures the container's software is current.

- Installs Lynis, a security auditing tool.

3. **Running initial audit for authentication:**

```
sudo lynis audit system --tests-from-group authentication
```

- Focuses only on authentication-related checks.
- Baseline **hardening index** recorded: 54.

Initial Critical Vulnerabilities:

- Multiple accounts with same UID — AUTH-9208
- Weak password hashing rounds — AUTH-9230
- Missing PAM module for password complexity — AUTH-9262
- Accounts without expiration dates — AUTH-9282
- Minimum password age not configured — AUTH-9286
- Default umask too permissive — AUTH-9328

Policy Alignment

Vulnerability	CIS Benchmark	Policy Purpose
Multiple accounts with same UID — AUTH-9208	CIS 6.2.5	Ensures accountability and traceability of user actions
Password hashing rounds — AUTH-9230	CIS 5.3.1	Strengthens password storage for authentication security

PAM module missing — AUTH-9262	CIS 5.3.2	Enforces password complexity to prevent weak passwords
Expiration dates missing — AUTH-9282	CIS 5.4.1	Ensures timely rotation of credentials
Minimum password age — AUTH-9286	CIS 5.4.2	Prevents immediate password reuse
Default umask — AUTH-9328	CIS 5.2.3	Enforces least privilege and secure file permissions

2. Detection and Analysis

Vulnerabilities Identified:

- **Duplicate UIDs:** `AnotherUser` and `Benny` shared UID 1001. This makes accountability difficult.
- **Password hashing rounds not configured:** Passwords are weaker due to low SHA crypt rounds.
- **Missing PAM module:** No enforcement of password complexity.
- **Accounts without expiration:** Some accounts could remain active indefinitely.
- **Minimum password age not set:** Allows immediate password reuse.
- **Permissive umask (022):** Allows world-readable/writable files, increasing risk of exposure.

Prioritization:

- **High Priority:** Duplicate UIDs, PAM module, password hashing rounds.

- **Medium Priority:** Account expiration, minimum password age, permissive umask.
-

3. Containment, Eradication, and Recovery

Remediation Steps and Codes Used

1. **Duplicate UID removal:**

```
sudo userdel -r AnotherUser
```

- Deletes the redundant account and its home directory.
- Aligns with CIS 6.2.5 for accountability.

2. **Password hashing rounds configuration:**

```
sudo vi /etc/login.defs
```

- Edited:

```
SHA_CRYPT_MIN_ROUNDS 5000
```

```
SHA_CRYPT_MAX_ROUNDS 10000
```

- Forces stronger hash iterations for stored passwords (AUTH-9230).

3. **PAM module installation:**

```
sudo apt update
```

```
sudo apt install libpam-passwdqc
```

- Enforces password complexity (length, character diversity, and reuse restrictions) (AUTH-9262).

4. **Set account expiration dates:**

```
sudo chage -E 2026-12-31 <username>
```

```
sudo chage -W 7 <username>
```

- **-E** sets the account expiration date.
- **-W** warns users 7 days before expiration.
- Ensures passwords are rotated regularly (AUTH-9282).

5. **Configure minimum password age:**

```
sudo chage -m 7 <username>
```

- **-m 7** sets minimum 7 days between password changes (AUTH-9286).

6. **Restrictive UMASK:**

```
sudo grep -RPi '(^|^[^#]*)\s*umask' /etc/login.defs /etc/profile*  
/etc/bash.bashrc*
```

```
sudo vi /etc/login.defs
```

- Found **UMASK 022** and changed it to **UMASK 027**.
 - Enforces least privilege for new files (AUTH-9328).
-

4. Post-Incident Activity

Verification and Comparison

Hardening Index Scores:

- Initial: 54
- Post-Remediation: 85

Analysis of Improvements:

- Unique UIDs enforced → improves traceability.
- Password hashes strengthened → improves authentication security.
- PAM module installed → prevents weak passwords.
- Accounts now expire → reduces stale credentials.
- Minimum password age set → prevents immediate password reuse.
- Default umask updated → reduces file exposure.

The system is now much more resilient against authentication-related attacks and aligns with CIS benchmarks.

Remaining Issues and Recommendations

Issue	Recommendation
Fail2ban not operational in container	Apply on host system to monitor failed logins and block attackers
Kernel logging (klogd)	Run <code>rsyslog</code> or <code>systemd-journald</code> on host for full log collection

Periodic audits

Run Lynis regularly to maintain compliance

New accounts

Ensure new accounts comply with expiration, complexity, and hashing rules

5. Reflection on the IR Process

Preparation:

Setting up the container, updating packages, and installing Lynis allowed a clear view of the system's initial weaknesses. The baseline audit provided measurable data to track improvements.

Detection and Analysis:

Identifying vulnerabilities and prioritizing high-risk issues guided remediation efforts. Container limitations made interpreting certain warnings (like systemd-based services) challenging.

Containment, Eradication, and Recovery:

Applying fixes directly addressed vulnerabilities. Challenges included ensuring changes persisted in a container environment and applying CIS-aligned policies correctly.

Post-Incident Activity:

Verifying remediations with Lynis demonstrated improvement, reinforcing the effectiveness of structured IR actions. The hardening index increase confirmed enhanced security posture.

Overall Reflection:

The IR process provided a clear, methodical approach to system hardening. Lessons learned:

- Systematic auditing is essential.
 - Prioritization ensures high-risk vulnerabilities are addressed first.
 - Understanding the operational environment is crucial when applying controls.
This structured approach can be applied to real-world systems to maintain continuous security and compliance.
-

6. Final Lynis Control Table

Lynis Control	Pre-Remediation	Post-Remediation	CIS Mapping	Action Taken
AUTH-9 208	Multiple accounts with same UID	No duplicate UIDs	CIS 6.2.5	Deleted duplicate account
AUTH-9 230	Weak password hashing	SHA_CRYPT_MIN=5000, MAX=10000	CIS 5.3.1	Configured <code>/etc/login.defs</code>
AUTH-9 262	Missing PAM module	libpam-passwdqc installed	CIS 5.3.2	Installed module
AUTH-9 282	Accounts without expiration	All accounts have expiration	CIS 5.4.1	Used <code>chage -E</code> and <code>chage -W</code>
AUTH-9 286	Minimum password age unset	Min age 7 days	CIS 5.4.2	Configured via <code>chage -m</code>
AUTH-9 328	UMASK 022	UMASK 027	CIS 5.2.3	Edited <code>/etc/login.defs</code>
